

History sniffing is a class of web vulnerabilities and attacks that allow a website to track a user's web browsing history activities by recording which websites a user has visited and which the user has not. This is done by leveraging long-standing information leakage issues inherent to the design of the web platform, one of the most well-known of which includes detecting CSS attribute changes in links that the user has already visited.

Despite being known about since 2002, history sniffing is still considered an unsolved problem. In 2010, researchers revealed that multiple high-profile websites had used history sniffing to identify and track users. Shortly afterwards, Mozilla and all other major web browsers implemented defences against history sniffing. However, recent research has shown that these mitigations are ineffective against specific variants of the attack and history sniffing can still occur via visited links and newer browser features.

Background

Early browsers such as Mosaic and Netscape Navigator were built on the model of the web being a set of statically linked documents known as pages. In this model, it made sense for the user to know which documents they had previously visited and which they hadn't, regardless of which document was referring to them. Mosaic, one of the earliest graphical web browsers, used purple links to show that a page had been visited and blue links to show pages that had not been visited. This paradigm stuck around and was subsequently adopted by all modern web browsers.

Over the years, the web evolved from its original model of static content towards more dynamic content. In 1995, employees at Netscape added a scripting language, JavaScript, to its flagship web browser, Netscape Navigator. This addition allowed users to add interactivity to the web page via executing Javascript programs as part of the rendering process. However, this addition came with a new security problem, that of these Javascript programs being able to access each other's execution context and sensitive information about the user. As a result,

shortly afterwards, Netscape Navigator introduced the same-origin policy. This security measure prevented Javascript from being able to arbitrarily access data in a different web page's execution context. However, while the same-origin policy was subsequently extended to cover a large variety of features introduced before its existence, it was never extended to cover hyperlinks since it was perceived to hurt the user's ability to browse the web. This innocuous omission would manifest into one of the well known and earliest forms of history sniffing known on the web.

History

One of the first publicly disclosed reports of a history sniffing exploit was made by Andrew Clover from Purdue University in a mailing list post on BUGTRAQ in 2002. The post detailed how a malicious website could use Javascript to determine if a given link was of a specific colour, thus revealing if the link had been previously visited. While this was initially thought of to be a theoretical exploit with little real-world value, later research by Jang et al. in 2010 revealed that high-profile websites were using this technique in the wild to reveal user browsing data. As a result, multiple lawsuits were filed against the websites that were found to have used history sniffing alleging a violation of the Computer Fraud and Abuse Act of 1986.

In the same year, L. David Baron from Mozilla Corporation developed a defence against the attack that all major browsers would later adopt. The defence included restrictions against what kinds of CSS attributes could be used to style visited links. The ability to add background images and CSS transitions to links was disallowed. Additionally, visited links would be treated identically to standard links, with Javascript application programming interfaces (APIs) that allow the website to query the color of specific elements returning the same attributes for a visited link as those for non-visited links. This ensured malicious websites could not simply infer a person's browsing history by querying the colour changes.

In 2011, research by then-Stanford graduate student Jonathan Mayer found that advertising company Epic Marketplace Inc. had used history sniffing to collect information about the browsing history of users across the web. A subsequent investigation by the Federal Trade Commission (FTC) revealed that Epic Marketplace had used history sniffing code as a part of advertisements in over 24,000 web domains, including ESPN and Papa Johns. The Javascript code allowed Epic Marketplace to track if a user has visited any of over 54,000 domains. The resulting data was subsequently used by Epic Marketplace to categorize users into specific groups and serve advertisements based on the websites the user had visited. As a result of this investigation, the FTC banned Epic Marketplace Inc. from conducting any form of online advertising and marketing for twenty years and was ordered to permanently delete the data it had collected.

Threat model

The threat model of history sniffing relies on the adversary being able to direct the victim to a malicious website entirely or partially under the adversary's control. The adversary can accomplish this by compromising a previously good web page, by phishing the user to a web page allowing the adversary to load arbitrary code, or by using a malicious advertisement on an otherwise safe web page. While most history sniffing attacks do not require user interactions, specific variants of the attacks need users to interact with particular elements which can often be disguised as buttons, browser games, CAPTCHAs, and other such elements.

Modern variants

Despite being partially mitigated in 2010, history sniffing is still considered an unsolved problem. In 2011, researchers at Carnegie Mellon University showed that while the defences proposed by Mozilla were sufficient to prevent most non-interactive attacks, such as those

found by Jang et al., they were ineffective against interactive attacks. By showing users overlaid letters, numbers and patterns, which would only reveal themselves if a user had visited a specific website, the researchers were able to trick 307 participants into potentially revealing their browsing history via history sniffing. This was done by presenting the activities in the form of pattern solving problems, chess games and CAPTCHAs.

In 2018, researchers at the University of California, San Diego demonstrated timing attacks that could bypass the mitigations introduced by Mozilla. By abusing the CSS paint API (which allows developers to draw a background image programmatically) and targeting the bytecode cache of the browser, the researchers were able to time the amount of time it took to paint specific links. Thus, they were able to provide probabilistic techniques for identifying visited websites.

Since 2019, multiple history sniffing attacks have been found targeting various newer features browsers provide. In 2020, Sanchez-Rola et al. demonstrated that by measuring the time a server takes to respond to a request with HTTP cookies and then comparing it to how long it took for a server to respond without cookies, a website could perform history sniffing. In 2023, Ali et al. demonstrated that newly introduced browser features could be abused also to perform history sniffing. One particularly notable example highlighted was that a recently introduced feature, the Private Tokens API, introduced under Google's Privacy Sandbox initiative with an intention to prevent user tracking, could allow malicious actors to exfiltrate users browsing data by using techniques similar to those used for cross-site leak attacks.

== References ==